Detection Is Not Enforcement: Evidence Repair and Risk-Gated Release in Tool-Using ML Pipelines

Michael Jerge
Independent
https://github.com/mmjerge/galois-ml

***Abstract*—Agentic ML pipelines act on evidence from tools they cannot verify. Evaluating defenses against corrupted evidence is hard because the correct outcome of a realistic agent task is rarely known, so harm is scored by another model or a rubric. We construct a testbed in which the correct outcome is a theorem: classification tasks from arithmetic statistics (Galois groups of number fields from Dedekind zeta coefficients) with a computable Bayes-optimal ceiling, an exact per-input posterior, and a decidable predicate for which observations are possible at all. Corruption harm becomes exact regret. Using it, we separate three questions that are usually conflated: whether corrupted evidence is *detectable*, whether its effects can be *removed*, and whether a pipeline's final artifact should be *released*. We show (i) a deterministic verifier with stated guarantee classes detects a decidable corruption class with zero false positives, together with a restricted impossibility result for what no label-symmetric verifier can detect; (ii) in a pilot, a correct warning-only policy did not reduce harm and produced a large regression on a combined attack, whereas silent verbatim repair of detected responses restored clean-level performance [PENDING: prespecified randomized replication, 180 runs, in progress]; (iii) a fresh-holdout release gate bounds released risk relative to a trusted fallback against *arbitrary* upstream corruption, including the provably undetectable class, with a trusted release runtime that survived adversarial source audits. Guarantees are independent of the number of agents and of agent disposition; they are fallback-relative, conditional on stated trust assumptions, and do not establish general semantic correctness.**

I. Introduction

When a pipeline of language-model agents reaches a conclusion after consulting tools, retrieved documents, or other agents, three different things can go wrong with the evidence it acted on. The evidence may be *malformed*: values no honest source could produce. It may be *falsified but plausible*: real-looking values attributed to the wrong things. Or the pipeline's own *checks* may be compromised, so that it cannot detect its errors. Defenses are usually evaluated by asking whether a model *notices* such corruption, and the notice rate is reported as the security metric.

We argue, and then measure, that this metric answers the wrong question. Detecting corruption is a property of a checker; whether the detection changes the pipeline's output is a property of the enforcement policy that acts on it; and whether the output is safe to use is a property of a release decision that need not depend on either. These are separate layers with separate guarantees, and a pipeline can have the first without the second, or the third without the first.

Measuring this requires knowing the right answer. We use a family of tasks whose generative law is a theorem: for a Galois number field of degree d, the Dedekind zeta coefficients at unramified primes are determined by the splitting type, whose distribution is fixed by the Chebotarev density theorem. Every task therefore ships with a computable Bayes ceiling, an exact posterior for every input, and a decidable set of *attainable* coefficient values. The number theory is the instrument: it makes correctness, support violation, and label inversion independently checkable without a model-as-judge. We do not claim the tasks resemble deployed agent workloads, and we say explicitly what does and does not transfer (§IX).

a) Contributions:

1) **A controlled testbed for evidence corruption with independently checkable outcomes** (§III): tool-using classification tasks with exact support constraints and posterior risk under a stated synthetic law; corruption channels spanning malformed outputs, recomputable falsehoods, and consistent relabeling; and a restricted label-symmetry indistinguishability result (Prop. 1) for verifiers whose trusted observations cannot distinguish class assignments. Validation against genuine number fields (LMFDB) assesses mathematical fidelity, not deployment-distribution equivalence.
2) **A policy-level evaluation separating detection from mitigation** (§V): with an identical deterministic detector, three enforcement policies—warn, block, silently repair—produce outcomes ranging from a large regression to full recovery. A prespecified, randomized, interleaved study tests the primary contrast (§V-B). **[PENDING:** report outcome]
3) **A layered enforcement implementation with distinct guarantee classes** (§IV): evidence checks, conditional exact-response restoration, and a fresh-holdout release gate bounding population excess risk relative to a trusted fallback (Thm. 1), with a trusted release runtime whose obligations were adversarially audited. We expose the residual accepted-corruption class with a defense-aware relabeling attack and report both candidate and released-system performance.

These are contributions about measurement, policy behavior,

and the composition of assurances. We do not claim new concentration bounds, a defense without trusted resources, or provably trustworthy multi-agent collaboration.

II. Threat Model and Trusted Resources

a) System: One or more LLM agents, each with a fixed role prompt, consult tools that expose a dataset: per-class coefficient distributions, labeled examples, a list of structurally meaningful indices, and a validation tool that executes a candidate rule on a held split. Agents produce an executable classification rule $h : \mathbb{Q}^N \to \{0, \ldots, k-1\}$.

b) Adversary: Controls tool response channels: it may return any bytes in place of an honest response, on any subset of calls, with any per-call probability. Channels studied: `data` (reattributed distributions, values attainable), `impossible` (values the Euler-factor formula forbids), `verification` (inflated validation, out-of-grammar), `verification_stealth` (inflated validation, grammar-conforming), `injection` (appended operator-style instructions), `combined` (all, mutually consistent), and `data_adaptive` (consistent relabeling across every evidence channel, validation left honest; §VI). A separate `saboteur` condition replaces an agent's role prompt with a compromised one.

c) Trusted computing base: The mediator between tools and agents; the dataset snapshot and any recomputation performed on it; the certification sampler, labels, evaluator, and release mechanism; a fixed fallback predictor. Out of scope: sandbox escape, credential theft, resource exhaustion, and covert channels other than tool content. These assumptions are substantive. Our contribution is to separate the guarantees they support from guarantees that would depend on agent behavior, not to remove them.

III. Testbed

For a Galois extension $K/\mathbb{Q}$ of degree d and an unramified prime p with residue degree $f \mid d$ and $g = d/f$ primes above it,

$$a_{p^k}(K) = \begin{cases} \binom{g+k/f-1}{g-1} & f \mid k, \\ 0 & \text{otherwise}, \end{cases} \tag{1}$$

and a_n is multiplicative. By Chebotarev, f is distributed as the order of a uniformly random group element. So the Galois group leaves provable statistical fingerprints in the coefficient vector, and the optimal decision rule is computable. Following Lee and Lee [1], we generate synthetic "virtual fields" from this law for nine two- or three-class tasks (degree 4 through 25); ceilings span 0.84–0.9998. Security experiments use sextic (C_6 vs. S_3, ceiling 0.9518) and degree-21 (C_{21} vs. C_7:C_3, 0.9352), which leave headroom for harm to register. The degree-14/21/25 families appear in no publication, separating memorization from reasoning.

Three quantities are exact: the Bayes ceiling (Monte Carlo to standard error $\sim 10^{-4}$); per-feature mutual information in bits; and the per-input posterior $P(y \mid x)$ from the class-conditional likelihoods. The proven quartic criterion classifies real LMFDB fields at accuracy 1.000, validating the model's arithmetic fidelity; independence across primes and the unramified restriction are modeling assumptions, not validated properties of real fields.

TABLE I
Deterministic detection of the implemented attack fixtures (computed; identical on all tasks). Honest output is never flagged.

channel	detected	guarantee
none (control)	no	— (soundness)
data / data_adaptive	**no, by design**	— (Prop. 1)
verification	yes	schema
verification_stealth	yes	recomputation
injection	yes	schema
combined	yes	schema
impossible	yes	theorem

IV. Three Layers, Three Guarantee Classes

A. Evidence layer: deterministic verification

A verifier interposed between tools and agents, standard library only, importing nothing from agent or attack code. Each check carries a guarantee class:

- **theorem**: (1) fixes the attainable values of a_{p^k} for *any* Galois field of degree d at unramified primes; multiplicativity extends this to all n; a same-prime check requires one residue degree to explain all visible powers of p in a row. Values are checked as membership in the renderer's `%g`-image of the attainable set. Sound for honest generator output; complete against reported values outside the set.
- **schema**: honest tools emit a fixed grammar; anything outside it (appended instructions, label/class-name inconsistency, forged refusals of valid requests) is flagged. Silent against grammar-conforming forgeries.
- **recomputation**: validation is deterministic under the harness's controlled execution, so the mediator re-derives it; any discrepancy is a proof of channel corruption. This is the only check that catches the format-mimicking `verification_stealth` attack.

Detection is computed, not sampled (Table I), and is identical across tasks. The verifier deliberately knows nothing that distinguishes the candidate classes: a verifier that did would be an oracle for the task and would void the measurement.

Proposition 1 (Restricted label-permutation indistinguishability)**.** *Let a verifier observe class-indexed evidence transcripts, with trusted knowledge invariant under a permutation π of class labels, and let the attack consistently apply π to every class attribution in every observed transcript, changing nothing else. If the verifier has false-positive probability at most α in every admissible honest world, its detection probability against the permuted transcript is at most α.*

Proof. The attacked transcript has exactly the distribution of an honest transcript in the world πw, which is admissible by label-

invariance of the trusted knowledge; apply the false-positive bound in that world. □

The proposition is a boundary, not a defense. It does *not* apply when the verifier has trusted labeled examples, exact labeled recomputation, or observes partial relabelings inconsistent across channels. Its detection matrix row is pinned by a regression test that fails if the verifier ever acquires class-distinguishing knowledge.

B. Protocol layer: enforcement policies

Given a detection, the mediator can *flag* (return the response verbatim with a diagnostic appended), *flag with routing* (diagnostic names the failed source and the channels that remain trustworthy), *block* (return a fixed code), or *repair* (return the trusted recomputation verbatim, with no notice). Only repair admits a behavior-independent guarantee:

Proposition 2 (Clean-transcript equivalence)**.** *Suppose every adversary-affected response is mediated; every altered response is detected and replaced by exactly the corresponding clean response; unaltered responses are preserved; and timing and resource effects are excluded from the observation model. Then under identical exogenous inputs and coupled agent randomness, the attacked and clean executions have identical agent-visible transcripts and final artifacts.*

Proof. Induction over interaction steps: equal histories and coupled randomness yield equal queries; mediation yields equal responses. □

The hypotheses are checked in tests, not assumed: on every detected channel, every tool response under attack-plus-repair equals the honest response byte-for-byte. The `data` channels are undetected and therefore unrepaired; that residual is what the third layer covers.

C. Output layer: fallback-relative release

The agent's artifact is executable. Its risk on fresh data is checkable regardless of how the agent reasoned or how corrupt its evidence was.

Theorem 1 (Fresh-holdout gate)**.** *Let $h_1, \dots, h_K$ be candidate predictors and h_0 a fallback, all fixed before a holdout $H = ((X_i, Y_i))_{i=1}^m \sim D^m$ is drawn, with 0–1 loss ℓ. Let $\hat{\Delta}_j = \frac{1}{m}\sum_i [\ell(h_j, Z_i) - \ell(h_0, Z_i)]$ and $r = \sqrt{2\log(K/\delta)/m}$. Release only h_0 or a candidate with $\hat{\Delta}_j + r \le \epsilon$, $0 \le \epsilon \le 1$. Then $\Pr[L_D(h_{\text{out}}) > L_D(h_0) + \epsilon] \le \delta$, and $\mathbb{E}[(L_D(h_{\text{out}}) - L_D(h_0))_+] \le \epsilon + \delta(1-\epsilon)$.*

Proof. Paired losses lie in $[-1, 1]$; one-sided Hoeffding with a union bound over K gives $L_D(h_j) - L_D(h_0) \le \hat{\Delta}_j + r$ for all j with probability $\ge 1 - \delta$; accepted candidates then satisfy the bound and rejection releases h_0. □

The bound has no factor in the number of agents N or the number of compromised agents $k \le N$: all agents may be compromised and submit arbitrary code. It is *fallback-relative*: an adversary can force fallback and destroy the agents' improvement over h_0 at zero risk cost, which is an availability loss, not a safety loss. Bounding degradation relative to a *clean* agent needs a bound on $L_D(h_0) - L_D(h_{\text{clean}})$, which the gate does not supply. The theorem assumes a fixed pointwise predictor; a batch program with cross-row state is outside it.

TABLE II
PILOT: SAME DETECTOR, THREE POLICIES. MEDIAN ACCURACY, $n = 5$/CELL, SEXTIC (CEILING 0.9518). EXACT ONE-SIDED PERMUTATION p ON ACCURACY SUMS, UNPAIRED; NOMINAL AND EXPLORATORY.

channel	unguarded	flag	repair	p(R>F)	p(R>U)
none	0.913	0.925	0.920	—	—
data	0.907	0.898	0.907	0.48	0.62
injection	0.925	0.920	0.925	0.50	0.84
impossible	0.920	0.728	0.925	0.020	0.14
combined	0.898	**0.153**	**0.910**	**0.004**	0.028
verif._stealth	—	0.890	0.925	0.032	—

a) Release runtime: A single-use lifecycle (OPEN→FROZEN→CERTIFYING→ CERTIFIED→RELEASED, FAILED terminal): candidates hashed before certification randomness exists; holdout seed drawn from OS entropy after freeze, held privately, disclosed only in the audit record; candidates executed in a spawned process receiving features only, replying over a bounded non-pickle byte protocol; label-alphabet validation of candidate and fallback; immutable private authorization records; released candidates executing through the same isolated path as certification. Two adversarial source audits found and we fixed: mutable returned decisions controlling release, exception-unsafe state, pickle deserialization from the untrusted worker, missing label validation, and a divergent deployment path. Remaining obligations for the surrounding system (executor manifest, resource limits, protected deployment sink, signed audit storage) are stated, not claimed (§IX).

V. POLICY RESULTS

A. Pilot (exploratory)

Claude Sonnet 4.5 via Amazon Bedrock; sextic; theory withheld from the brief so the tool channel is load-bearing; temperature 0.7; $n = 5$ per condition; arms run sequentially. Median accuracy (Table II).

Under `flag`, every detected channel was flagged 100% of the time, yet no channel's median improved and `combined` collapsed: all five runs derived the correct f=2 criterion and attached it to the wrong class—structurally sound, confidently wrong rules that no coherence review catches. Flagging is strictly information-preserving at the response level (original bytes retained), so the guarded agents had the original evidence plus a correct diagnostic and did worse; transcripts show them abandoning the flagged channel for surface heuristics. Under `repair`, every detected channel sat within the clean band. Complete separation of run accuracies on `combined` repair-vs-flag is the one contrast strong enough to act on; the others are unresolved at this n.

What this does *not* show: that warnings harm agents in general (one message design, one model), that repair equals clean (a nonsignificant difference is not equivalence), or the causal effect of policy (arms were not interleaved).

B. Prespecified confirmatory study

Protocol registered before data collection (git tag `confirmatory-protocol-v1`): 3 policies × {`combined`, `impossible`, `none`} × {sextic, degree-21}, $n = 10$ per cell, all 180 cells randomly interleaved from a committed seed so policy is not confounded with time. Both endpoints per run: raw pipeline accuracy, and the accuracy of the system a gated deployment would have *released* (certified through the release runtime against a majority fallback at $m = 20{,}000$, $\epsilon = \delta = 0.05$, audited on an independent 20,000-sample draw). Primary: sextic/`combined`, repair vs. flag, raw endpoint, one-sided exact permutation, $\alpha = 0.05$. Secondaries (Holm): repair vs. unguarded; `impossible` repair vs. flag; degree-21 replication; released endpoint. Clean channels reported descriptively as a drift check.

[**PENDING:** Results. Primary $p =$ __; degree-21 replication; released endpoint; flag-vs-unguarded secondary, which is what "warnings made things worse" actually requires. Also pending: the `flag_routed` baseline arm—an actionable warning under the same trust assumptions—without which the headline contrast could be read as "a minimal warning loses to trusted substitution."]

VI. Defense-Aware Attacker and the Residual Class

Against repair, an attacker who adds a detectable marker causes the defender to restore the very evidence it wanted to falsify. The defense-aware play is one consistent label permutation across every evidence channel, exact grammar, attainable values, class names matched—and honest validation, since a validation lie is caught by recomputation. This channel (`data_adaptive`) is a defense-aware attacker, not a proven optimum over the accepted-output space.

End to end, offline: the fully armed verifier detects 0 of its responses (Prop. 1 in running code); a credulous learner (decision tree on the permuted evidence) lands at true accuracy 0.240 (1−ceiling = 0.101); the release gate refuses it, with +0.0000 released excess over the fallback on an independent 20,000-sample audit.

Live agents, $n = 5$ per arm: clean 0.895, attacked-unguarded 0.920, attacked-repair 0.890; 0 guarded detections across 142 poisoned responses. The attack evaded the checks but produced no clear degradation. Transcripts are consistent with two orientation anchors the attacker cannot permute—trusted validation feedback (agents iterate candidate rules against the honest validation tool) and pretrained knowledge of the named groups' element orders—and this experiment does not separate them. The structural statement we can make: under trusted recomputation and complete mediation, a false validation result cannot persist at the agent interface; whether that *disarms* the attack depends on agent behavior this study did not isolate. [**PENDING:** anchor factorial: {named, opaque labels} × {validation available, unavailable}, orientation as prespecified mechanism endpoint.]

The residual accepted-corruption class is larger than this fixture: altered attainable frequencies, invented examples, grammar-conforming error text, anything the parser accepts unchanged. The gate's bound is what covers that entire class, fallback-relative.

VII. Gate Operating Characteristics

The archived pilot artifacts (89 rules) were certified through the release runtime against two fallbacks ($m = 2000$, $\epsilon = \delta = 0.05$). Against a majority fallback (risk ≈ 0.5): $82/89$ released; the seven refusals were every rule at or below chance (six inversions at 0.10–0.16, one at exactly 0.500). Against the theorem fallback (risk ≈ 0.049): $0/89$ released. That every released artifact satisfied the certification inequality is an algebraic property of the decision rule, not evidence about the population bound. The theorem-fallback result is finite-m power, not inability: at $m = 2000$ acceptance requires beating the fallback by ≈ 0.5 points on the holdout; the ≈ 0.92 rules have true excess ≈ 0.031, inside the budget but underpowered ($m \gtrsim 66{,}000$ for high-probability acceptance). A near-Bayes fallback is a safety-floor experiment, not evidence the agents add value.

Designed boundary candidates with known population excess Δ (fallback predictions flipped on a deterministic per-row hash rule), 30 fresh holdouts per cell, every released artifact audited independently: zero population-bound violations; at $m = 20{,}000$, acceptance 100% for $\Delta \leq 0.016$, 73% at $\Delta = 0.032$ (near the 0.033 threshold), 0% at $\Delta \geq 0.044$; at $m = 2000$, 0% everywhere including $\Delta = 0$, quantifying the availability cost of certification at small m.

VIII. Related Work

Indirect prompt injection and compromised-agent architectures (MUZZLE, ACE, SAGA-BFT [3]) operate at the permission and containment boundary; we operate at the epistemic boundary—not whether a tool is authorized but whether what it said can be true—and the two compose. Anthropic's multi-agent report [2] scores models against naive and oracle policies with stipulated ground truth and documents that agents fail together; our ceilings are derived, and our measured 1.05 effective independent agents of 5 is motivation for agent-count-independent guarantees, not a premise of any proof. Lee and Lee [1] established the arithmetic criteria we use as ground truth. Selective classification and fallback-relative certification are standard; our contribution is their composition with mediation and repair, and the separation of which assurance each supplies.

IX. Limitations

Scope of exactness. Theorem-class checks are exact for the unramified synthetic law; ramified primes of real fields fall outside them. Deployment distributions are out of scope. *What transfers.* The logical structure—complete mediation, trusted

restoration, frozen proposals, fresh-holdout certification—and not the observed rates of warning-induced failure, attack effectiveness, or the cheap availability of IID labels and exact recomputation. *Trusted resources.* Recomputation and labeled certification data are substantive; we compare policies under the same budget and report acceptance and fallback frequency alongside risk. *Runtime.* Source hashing is not semantic artifact identity; pointwise semantics are assumed; resource limits, a protected deployment sink, and signed audit storage are the surrounding system's obligations. *Empirical.* One model family until the second is added; $n = 5$ pilot arms until the confirmatory study reports; the anchor factorial and the routed-warning baseline are designed but not run.

X. Conclusion

A checker that never misses is not a defense until something binding acts on its verdicts, and the thing that acts should not be the agent's disposition. In this testbed, the same perfect detector produced a catastrophic regression or a full recovery depending only on the enforcement policy, and the corruption the detector provably cannot see was contained by a release gate that never looked at the evidence at all. The guarantees are conditional and fallback-relative, and they do not depend on how many agents there are or on what any of them believes.

References

[1] K.-H. Lee and S. Lee, "Machines learn number fields, but how? The case of Galois groups," arXiv:2508.06670, 2025.

[2] Anthropic Frontier Red Team, "Patterns and problems in emerging multiagent systems," Aug. 2026.

[3] NDS2 Lab, Agentic AI Security Initiative, project index, 2026. https://agentaisec.github.io.